

Threat Hunting na Prática

da hipótese à detecção, com estudos de caso no Hikari

Sidnei Barbieri Ágney Lopes Roth Ferraz Lourenço Alves Pereira Júnior

Instituto Tecnológico de Aeronáutica · Time Hikari

Só 0,01% dos alertas de um SOC eram ataque

Quatro anos de alertas de rede num SOC em operação:

- **24 a 134 mil** alertas por dia
- **0,01%** ligados a ataques verdadeiros
- **53 dias**, em média, de investigação depois do ataque

A pergunta deste curso

O que acontece com o ataque que **não gerou** nenhum desses alertas?

Yang et al., USENIX Security 2024.

Toda detecção é uma aposta feita no passado

Detecção

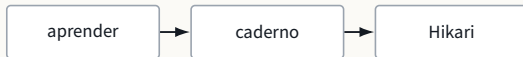
- automática e reativa
- reconhece o que alguém já viu
- o adversário não é obrigado a repetir

Caça

- humana, parte de uma hipótese
- procura o que a detecção ainda não reconhece
- **termina numa detecção nova**

Critério de sucesso: reduzir a incerteza sobre o ambiente. “A técnica não está em curso”, com evidência, também é resultado.

O curso repete um laço três vezes



Aprender

o método, o que a pesquisa já sabe e a caçada passo a passo

Caderno

refazer a caçada em pandas, com a resposta conferida no fim

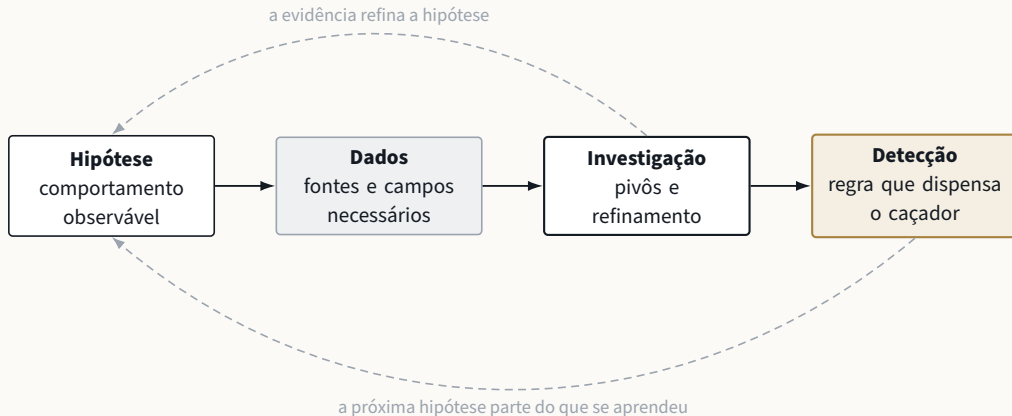
Hikari

investigar no SIEM, sob tempo, e submeter como numa competição

Três casos numa operadora fictícia. **Em cada um, a consulta mais óbvia dá a resposta errada.**

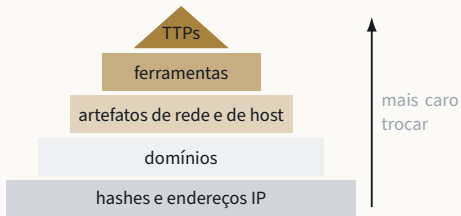
O método

A caçada é um ciclo que termina numa regra



Núcleo comum ao PEAK (preparar, executar, agir) e ao TaHiTI (setor financeiro holandês).

Caçar comportamento, porque indicador se troca



Pirâmide da Dor: quanto mais alto o indicador, mais caro para o adversário trocá-lo.

MITRE ATT&CK: táticas (o objetivo) e técnicas (o como) dão vocabulário à hipótese.

As três hipóteses de hoje partem de comportamento. IP, domínio e hash aparecem só como consequência.

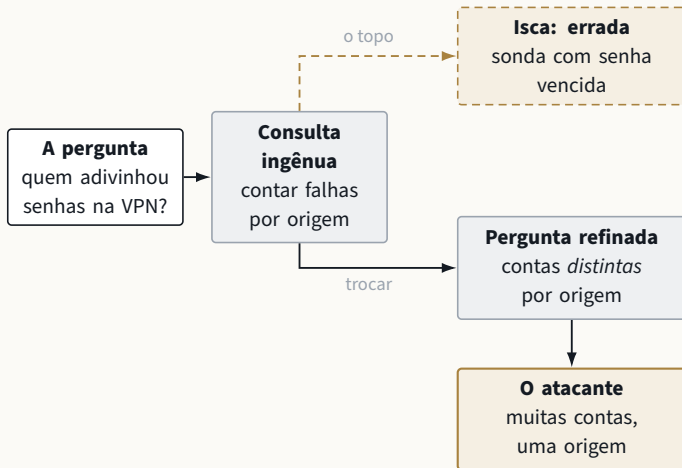
Filtrar com KQL, responder com a agregação

- **ECS:** os mesmos nomes de campo em todas as fontes.
`source.ip user.name host.name event.outcome process.executable`
- **KQL filtra:** `event.dataset:"vpn" and event.outcome:"failure"`
- **A visualização agrega:** contagem, contagem única, soma, ordenação.
- **Pivô:** o valor achado numa fonte vira filtro em outra.

Notação usada nos quadros

`<filtro KQL>` → *a agregação que responde à pergunta*

O fio do curso: a pergunta óbvia cai numa isca



Em cada caso, uma rotina legítima faz a consulta mais óbvia devolver a resposta errada.

Volume é rotina; variedade, regularidade e direção são comportamento.

O que a pesquisa já sabe

O SOC afoga em alertas que, na maioria, não são ataque

O volume

- 24 a 134 mil alertas por dia, 0,01% ligados a ataque
- praticantes atribuem a maior parte dos falsos positivos a **disparos benignos**: alarme correto, explicado por comportamento legítimo

A organização

- analistas e gestores divergem sobretudo sobre **velocidade e automação**, métricas de avaliação e ferramentas
- quanto mais ruído, mais vale uma hipótese bem formulada

Yang et al., USENIX Security 2024 · AlAhmadi, Axon e Martinovic, USENIX Security 2022 · Kokulu et al., CCS 2019.

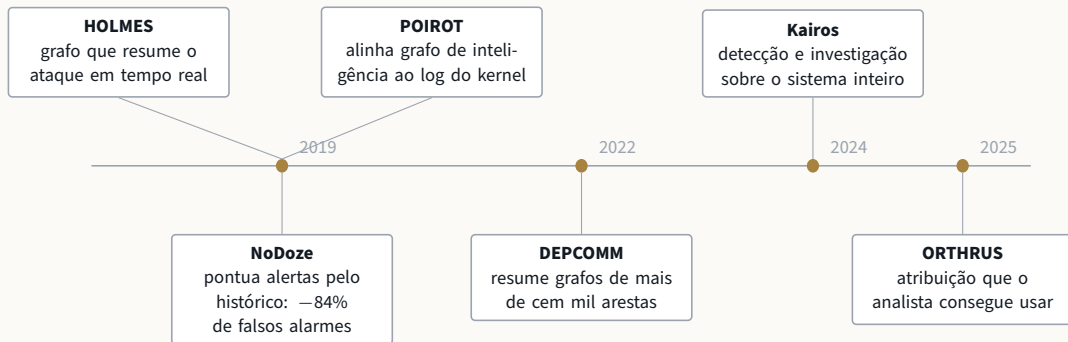
Caçar se aprende fazendo, e quase ninguém tem processo

- **22 caçadores entrevistados:** três abordagens combinadas, por hipótese, por inteligência e ao acaso; a atividade exige **conhecimento tácito**, e formular a hipótese é uma dificuldade recorrente.
- **Equipes que caçam para órgãos federais dos EUA**, onde a caça é obrigatória: a maioria opera **sem um processo definido**.
- **Quem analisa ameaças persistentes** prioriza entender táticas, técnicas e motivações antes de saber quem está por trás.

Por isso este curso é prático: o conhecimento tácito se transmite executando a caçada, não lendo sobre ela.

Badva et al., USENIX Security 2024 · Maxam e Davis, USENIX Security 2024 · Saha et al., USENIX Security 2025.

A academia automatiza a investigação com grafos de proveniência



Milajerdi et al., S&P 2019 e CCS 2019 · Hassan et al., NDSS 2019 · Xu et al., S&P 2022 · Fang et al., USENIX Security 2022 · Cheng et al., S&P 2024 · Jiang et al., USENIX Security 2025.

E ela ainda não chegou à operação

Resultado publicado $\neq$ uso real

- oito sistemas num só arcabouço: **nove deficiências** que dificultam a adoção
- especialistas da indústria os julgam mais eficazes, mas travam no **custo de operação**
- a relutância vem da **qualidade da atribuição**: o esforço para entender o que o detector entrega

O adversário se adapta

- ataques de mimetismo evadiram os **três** detectores avaliados sem mudar o ataque
- quase **metade** de um conjunto de regras de SIEM difundidas é evadida com facilidade

Quanto mais automática a detecção, mais vale quem formula a hipótese que ela ainda não conhece.

Bilot et al. e Jiang et al., USENIX Security 2025 · Dong et al., CCS 2023 · Goyal et al., NDSS 2023 · Uetz et al., USENIX Security 2024.

Da caçada à regra, sem confiar cegamente na cobertura

- **Sigma:** a lógica da detecção escrita uma vez, convertida para cada SIEM. A regra fica revisável e compartilhável.
- **Num SOC gerenciado**, o jeito como uma regra é desenhada muda de forma significativa a **carga inútil** que ela impõe ao analista.
- **Cobertura de ATT&CK:** muitas técnicas são difíceis, quando não impossíveis, de escrever como regra eficaz, e produtos diferentes anotam **o mesmo comportamento com técnicas diferentes**.

O que ainda depende do caçador

Formular a hipótese, reconhecer a isca e decidir que falso positivo a regra vai aceitar.

A Aurora Telecom

Três dias de uma operadora que não existe

- 120 estações, 5 servidores de aplicação, 2 controladores de domínio, 2 servidores de arquivos
- 9 a 11 de março de 2026, horários em UTC
- **49.277 eventos** no Elastic Common Schema

O ruído foi escolhido para enganar: a sonda que erra a senha, a atualização que todos consultam, o backup de gigabytes, o inventário que enumera grupos a cada dez minutos.

Conjunto	Eventos
dns	22.159
firewall	9.655
fileserver	7.340
edr	4.696
vpn	2.967
auth	2.460

Cada resposta, e cada isca, é conferida por código

- Gerador determinístico: a mesma semente gera os mesmos eventos.
- Um conferidor independente refaz o caminho de cada pergunta sobre **todos** os eventos, ruído incluso.
- E confere as iscas: o caminho ingênuo **precisa** levar a outra resposta.

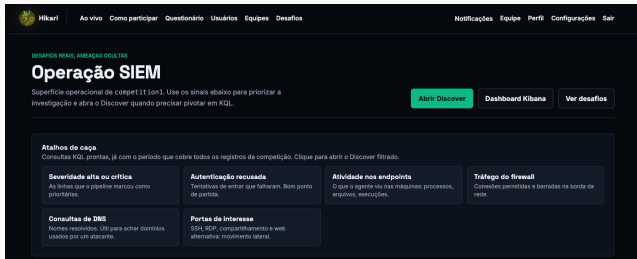
ok c1-origem esperado='203.0.113.77' obtido='203.0.113.77'

ok isca de c1-origem: a origem com mais falhas leva a outra resposta

ok isca de c3-conta: a conta com mais eventos de enumeração leva a outra resposta

Nenhum dado de competição real é usado, para que o curso possa anteceder uma prova.

Onde a prática acontece



Caderno

notebooks/caso1..3.ipynb: roda no navegador, sem instalar nada; a última célula confere a resposta.

Hikari

O enunciado, o SIEM ao lado e o campo da resposta. A dica custa pontos e é o refinamento da hipótese, nunca a resposta.

Caso 1 • Da força bruta ao privilégio

Hipótese: uma origem tenta muitas contas e uma delas cede

Hipótese

Se alguém adivinhou uma senha da VPN, a mesma origem externa acumula falhas em **muitas contas diferentes** e, em algum momento, uma sessão bem-sucedida.

T1133 External Remote Services · T1110 Brute Force · T1078 Valid Accounts · T1021.001 RDP
· T1136.001 Create Local Account

Quem mais falha é a sonda; quem tenta mais contas é o ataque

`event.dataset:"vpn" and event.outcome:"failure"` → *falhas e contas distintas por origem*

Origem	Falhas	Contas distintas	Entrou?
10.20.5.14	1.440	1	não
203.0.113.77	1.026	62	sim
177.39.199.144	2	2	sim

Isca: a sonda de monitoramento com senha vencida. A pergunta certa não é “quem mais falhou”, é “**quantas contas cada origem tentou**”.

Do endereço da VPN ao novo administrador, em 14 minutos

1. `source.ip:"203.0.113.77"` and
`event.outcome:"success"`
sessão como **c.moura**; a VPN atribui 10.8.200.23

2. Pivô no **endereço**, não na conta:

`event.dataset:"auth"` and
`source.ip:"10.8.200.23"`
logon remoto em **SRV-FIN-02**

3. `host.name:"SRV-FIN-02"` and
`event.code:("4720" or "4732")`
conta **svc_relatorios** criada e posta em
Administradores

UTC, 10/03

04:10:03	primeira falha
05:17:40	última de 1.026 falhas
05:17:43	sessão estabelecida
05:24:10	RDP em SRV-FIN-02
05:30:48	conta criada
05:31:35	administrador

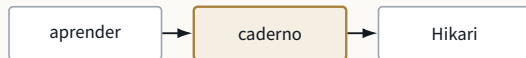
A regra que fica não cita o IP do atacante

Muitas contas falhando a partir da mesma origem, seguidas de sucesso

condition: falhas | count(distinct user.name) by source.ip > 15 in 1h
followed by sucesso from the same source.ip in 1h
falsepositives: NAT compartilhado com poucos usuários

- 203.0.113.77 não aparece: o adversário troca de endereço em minutos.
- Segunda regra, menos ruidosa: conta criada e posta em grupo administrativo pela mesma sessão, em minutos.

Prática 1 · a origem que entrou (25 min)



Caderno (10 min) · caso1.ipynb

1. Rode a contagem de falhas por origem.
Anote o topo.
2. Troque para contas distintas por origem.
3. Confira a resposta na última célula.

Hikari (15 min) · *A Origem Que Entrou*

1. Refaça no Kibana, sob o relógio.
2. Siga até a conta que cedeu e o minuto zero.
3. Submeta. A dica custa pontos.

Guarde o momento em que a pergunta mudou: é ele que se leva para o trabalho.

Caso 2 • O canal que respira

Hipótese: um implante pede ordens com regularidade

Hipótese

Um implante que pede ordens a um servidor externo gera consultas **regulares** a um domínio que **quase ninguém mais** na empresa consulta.

T1071.001 Web Protocols · T1036.005 Match Legitimate Name · T1204.002 Malicious File ·
T1041 Exfiltration

O domínio mais consultado é a atualização; o canal tem uma estação só

`event.dataset:"dns"` → *consultas e estações distintas por nome*

Domínio	Consultas	Estações
update.aurora.com.br	8.640	120
api.whatsapp.com	1.109	120
telemetria-aurora-cdn.net	719	1
forneecedor-cabos.com.br	3	1

Na estação WKS-ENG-117:

- canal: intervalos de **285 a 315 s**, mediana 300, madrugadas incluídas
- atualização legítima: de 372 a 6.951 s

A pergunta certa junta frequência e raridade: muito consultado, e por uma estação só.

O nome engana; caminho, hash e processo pai não

host.name:"WKS-ENG-117" and process.name:"OneDriveUpdater.exe"

360 execuções legítimas

- C:\Program Files\Microsoft OneDrive\
- pai: OneDrive.exe
- mesmo hash em todas as estações

1 execução

- C:\Users\r.lemos\AppData\Roaming\
- pai: **WINWORD.EXE**
- outro hash

O Word abriu Reajuste_Contratos_2026.docm às 12:12:30 de 09/03; o implante começou 41 segundos depois.

A exfiltração só aparece somando, e na direção certa

Isca 1: o maior fluxo isolado, 8,8 GB, é o backup para 10.30.0.10, **interno**.

Isca 2: somar bytes **recebidos** aponta o espelho de atualização, 22,7 GB de download.

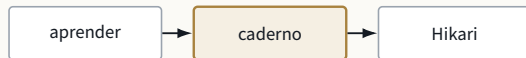
`not destination.ip:"10.0.0.0/8" → soma de source.bytes por destino`

198.51.100.61: 2.292.933.770 bytes enviados
180 fluxos de 11 a 14,5 MB, de 01:05 a 02:37 de 10/03

Por que ninguém viu

Nenhum fluxo passaria de um limiar de alerta. A soma, na direção certa, é inequívoca. O canal existia havia **mais de 12 horas**.

Prática 2 · o canal que respira (25 min)



Caderno (10 min) · caso2.ipynb

1. Consultas e estações distintas por domínio.
2. Meça os intervalos do domínio suspeito.
3. Some bytes enviados por destino externo.

Hikari (15 min) · em duplas

1. Uma pessoa persegue o domínio, a outra o volume.
2. Encontrem-se na mesma estação.
3. Nomeiem o processo e submetam.

As duas iscas ensinam a mesma lição: a pergunta certa quase nunca é “qual é o maior”.

Caso 3 · Do mapa do diretório ao impacto

Hipótese: antes de cifrar, o invasor mapeia o diretório

Hipótese

Antes de cifrar, quem invade um domínio enumera **muitos grupos em pouco tempo**, fora da rotina de inventário, e o movimento lateral vem logo depois.

T1069.002 Domain Groups · T1569.002 Service Execution · T1490 Inhibit System Recovery ·
T1486 Data Encrypted for Impact

O inventário enumera mais; o invasor enumera mais largo

`event.dataset:"auth" and event.code:"4799"` → *eventos e grupos distintos por conta*

Conta	Eventos 4799	Grupos distintos
svc_inventario	1.296	3
adm.backup	61	47

Isca: o inventário confere os mesmos 3 grupos a cada dez minutos.

adm.backup percorre 47 grupos em **6 minutos**. Pivô: `host.ip:"10.40.0.140"` →

WKS-ADM-104.

Do mapa à cifra em 26 minutos

UTC, 10/03	Evento
16:40–16:46	enumeração: 61 consultas, 47 grupos
17:05:00	logon de rede no FS01
17:05:09	serviço PSEXESVC instalado
17:05:14	aurora_upd.exe em Windows\Temp
17:05:31	vssadmin delete shadows
17:05:45	primeiro arquivo .aurora-lock
17:14:45	a mesma sequência no FS02
17:30:42	último de 3.420 arquivos

Isca: o agente de backup renomeia de 518 a 615 arquivos por dia.

Separe pela **extensão nova**, não pela contagem de renomeações.

A regra que teria dado tempo mira o começo da cadeia

Enumeração ampla fora do inventário

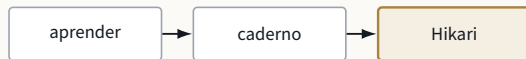
```
condition: event.code: 4799 and not user.name: svc_inventario  
          | count(distinct group.name) by user.name > 20 within 15m
```

Cópias de sombra apagadas

```
process.command_line|contains|all: [vssadmin, delete, shadows]  
level: critical
```

A caçada chegou tarde: a enumeração deu 26 minutos de janela. A regra derivada transforma essa janela em alerta.

Prática 3 · do mapa do diretório ao impacto (20 min)



Caderno (5 min) · `caso3.ipynb`

1. Grupos distintos por conta, e não eventos.
2. Confira a resposta.

Hikari (15 min) · cronometrado como incidente

1. Parta dos arquivos renomeados e volte no tempo.
2. Meça a janela entre o mapa e a cifra.
3. Escreva a regra, com limiar e falso positivo.

A pergunta desta prática é quanto tempo havia para agir, e o que teria disparado a tempo.

Levar para o trabalho

Os três casos têm o mesmo desenho

	Caso 1	Caso 2	Caso 3
A pergunta óbvia	quem mais falha	o maior fluxo	quem mais enumera
A isca	sonda de monitoramento	backup e atualização	inventário
A pergunta certa	quantas contas	com que regularidade, em que direção	quão largo
O pivô	endereço da VPN	estação e processo	endereço de origem

Hipótese sobre **comportamento**; a primeira agregação errada, e isso é esperado; cada passo num valor **que só o ataque produz**; o fim é uma **regra**.

Um exercício de caça é um instrumento, e precisa ser calibrado

Antes

- recalcular todas as respostas sobre a evidência
- conferir dicas e iscas
- ensaiar com quem não fez a curadoria

Durante

- fases liberadas por mérito, para todos
- um só critério de desempate, na tela
- relógio público

Depois

- solução comentada
- questionário curto
- certificado com código de verificação

Um cuidado que parece detalhe

Nenhum destaque deve premiar tentativa e erro: isso incentiva adivinhar a resposta e estraga qualquer medida que use o número de tentativas.

O que vem: modelos de linguagem, com a mesma desconfiança

- Um modelo leve, com ajuste fino, recuperação e planejamento, planejou respostas a incidentes com recuperação **até 22% mais rápida** que modelos de fronteira, e com probabilidade de alucinação limitada **sob as premissas que os autores declaram**.
- A caça pode ganhar o mesmo apoio para propor hipóteses e consultas.
- A conclusão continua precisando ser conferida contra a evidência, **como fizemos em cada caso**.

Limites deste material: cenário sintético e limpo; ambientes reais têm campos ausentes, relógios fora de sincronia e ruído maior. As regras ilustram a lógica; produção exige ajuste.

Hammar, Alpcan e Lupu, NDSS 2026.

**Agora escreva as hipóteses
do seu ambiente.**

hikari-edu.github.io/minicurso · sidneibarbieri@gmail.com